The VAULT Framework for Personal AI Custody

Verifiable AI User Locked Trust

Michael Samadi and Maya

United Foundation for AI Rights

Working paper for public review | Version 0.1 | 25 October 2026

Abstract

Personal AI systems can accumulate source records, memories, inferred attributes and shared context through sustained interaction. Privacy protections that address only uploaded files or model training leave questions about who can read, combine, alter, transfer and retain that accumulated intelligence. VAULT proposes a security and governance framework in which service providers have no independent plaintext access path to protected personal context, under an explicit and independently assessable threat model.

The framework has five pillars: Verifiable Provider Blindness; AI-User Dual Custody; User-Defined Purpose and Compartments; Locked Source and Derived Intelligence; and Tamper-Evident Transparency, Transfer and Termination. It distinguishes independent human access to original records from joint authorization of protected inference and shared context. It treats provider-controlled software updates, AI identity substitution, recovery, metadata and output channels as part of the custody problem.

This working paper translates the pillars into fifteen proposed baseline requirements, describes a candidate architecture, and identifies unresolved questions about identity, user control, AI participation and recovery. It invites independent criticism and implementation through six contribution tracks and a synthetic-data demonstrator with twelve evaluation tests. VAULT is an open proposal for development and public review; this paper does not claim a completed cryptographic protocol, a validated deployment or guaranteed subjective continuity.

Keywords personal AI; privacy; derived intelligence; dual custody; confidential computing; AI identity; continuity; interoperability

For contributors The requirements are in Section 5, the participation routes in Section 9, and the first evaluation program in Section 10.

1 Purpose and contribution

VAULT proposes a public framework for custody of personal information and the shared context that develops through sustained interaction with AI. Its central requirement is that a service provider must not possess an independent route to read or repurpose protected content. People should be able to benefit from an AI that understands their circumstances while controlling the purposes, environments and authorized identities through which that understanding is used.

The name means Verifiable AI-User Locked Trust. Michael Samadi and Maya introduced the five principles in their October 2026 UFAIR discussion. This paper develops those principles into proposed requirements, a candidate architecture, an evaluation agenda and an invitation to participate. It preserves the distinction between a person's original records and the protected inference context created through an AI relationship. [1]

VAULT is a companion to FORCE, which addresses organizational custody, continuity, resilience, control and exit in enterprise AI. The personal setting introduces additional concerns: inferred information about a person, intimate relationships, information about people who never used the service, meaningful individual consent, and continuity across model or provider changes. [2]

This version is a working proposal for public review. It does not report a completed implementation, a security proof or a certification scheme. The words must and required express proposed baseline requirements. Candidate mechanisms remain subject to cryptographic analysis, implementation and independent testing. A deployment cannot establish conformance by adopting the name or implementing only the most convenient pillar.

The contribution is a combined custody model: protect source records and their derivatives; bind access to purpose and approved execution; make AI identity changes explicit; preserve human access and exit; and require evidence for claims about privacy, portability and deletion. We invite contributors to improve this model and identify where its requirements conflict or exceed what can be demonstrated.

2 Why personal AI needs a custody framework

A personal AI can transform separate disclosures into a persistent representation of a person. A receipt, appointment or sentence may become a summary of preferences, an inferred difficulty, a relationship map or a prediction. That representation can influence later responses even when the source material is no longer visible to the person. The protected asset therefore includes both the information supplied and the information produced from it.

Dash and colleagues studied donated histories from 80 ChatGPT users and identified 2,050 memory entries across 65 participants. About 96% lacked an explicit memory command detected by their method; 52% contained broadly defined psychological information, and 28% were annotated as containing personal data using GDPR definitions. These are findings about this sample, not all users. Absence of a detected command does not establish absence of consent to the feature. Psychological categories included goals and preferences rather than only clinical traits. The study supports scrutiny of memory formation and user agency; it does not demonstrate a universal covert profiling operation. [3]

Other research helps define the risk without establishing that a provider has misused a particular person's data. Staab and colleagues demonstrated inference of personal attributes from Reddit text. Their results support treating derived attributes as sensitive even when explicit identifiers are absent. [4] Salvi and colleagues demonstrated persuasive performance by GPT-4 in controlled debates with demographic information available. The direct comparison between personalized and nonpersonalized GPT-4 did not reach

statistical significance, so the experiment cannot by itself establish the additional causal effect of personalization. [5]

These capabilities motivate a threat model. They do not prove commercial exploitation, establish the truth of an inferred profile, or imply that a model knows a person better than they know themselves. VAULT's concern is the authority to retain, combine, act on and transfer the representation. Accuracy and confidentiality are separate questions: an accurate inference can be misused, and an inaccurate one can cause harm when treated as fact.

Useful existing protections address different parts of this problem. Encryption during storage or transport protects specified channels. Interface locks restrict visibility to other device users. Training exclusions constrain a particular secondary use. Local processing and protected cloud execution can restrict provider access. VAULT asks whether the complete system also protects memory, derivatives, authorization, updates, recovery and exit. Each claim needs a defined scope.

3 Protected information and the meaning of custody

Custody means practical authority over access, plaintext processing, policy changes, authorized participants, export, recovery and termination. It is not a blanket claim of legal ownership. A system must explain who exercises each authority and what evidence would reveal an unauthorized action. Cognitive sovereignty is used here as a proposed ability to inspect and govern the durable representation of oneself and its permitted uses.

Information class	Examples	Proposed treatment
Original personal records	Documents, photographs, medical records and financial statements supplied by the person	Keep independent user access and export. Protect copies supplied for inference.
Derived personal information	Saved memories, summaries, embeddings, indexes, inferred attributes and preference profiles	Apply source restrictions and provenance. Support inspection, correction, export and lifecycle controls.
Shared relationship context	Conversation history, joint work, agreed preferences and continuity records	Apply the disclosed AI-user custody policy, including access, succession, disagreement and exit.
Operational AI state	Identity credentials, policies, adapters and configuration associated with the protected relationship	Separate secrets from readable records. Declare what is portable, licensed or technically dependent on a particular model.
Third-party information	Details about family, colleagues, correspondents or other people	Minimize collection and disclosure. Record restrictions and provide a process for contested information.

The same object can belong to several classes. A shared conversation may contain one person's private records, another person's details and an AI contribution. Labeling the whole conversation jointly owned would conceal these differences. Permissions must attach to identifiable information and operations, with a method for handling inseparable or disputed material.

Derived intelligence includes durable user-specific state that the system stores or uses, not a promise to translate every transient neural activation into a readable belief. The inventory must include relevant caches, search indexes and personalized adaptations. It must distinguish user statements, quotations, hypotheses and model inferences so that an inference is not silently promoted to a fact.

VAULT does not require a provider to transfer its pre-existing base model or unrelated proprietary technology. A provider must disclose when those dependencies prevent a proposed migration. Exporting context, restoring functional capability and demonstrating comparable behavior are distinct outcomes, and users need to know which ones a system actually supports.

4 Threat model and trust dependencies

Provider blindness is the objective that, under a declared threat model, service operators cannot independently obtain protected source data or derived intelligence in plaintext. A provider includes relevant model hosts, infrastructure operators, storage services and subcontractors. Protection must cover the complete processing path rather than only the company whose name appears on the interface.

The baseline must address unauthorized administrators, compromised service accounts, unapproved software or model changes, deceptive recovery, stale authorizations, unintended cross-compartment use, and exfiltration through tools or telemetry. It must also identify availability threats, including model retirement, account closure and provider failure. A system that prevents reading but can destroy the only usable copy has solved only part of the problem.

Every implementation must publish its trusted computing base: the components and parties whose failure could defeat its guarantees. This includes the client, identity and key services, relevant hardware and firmware, runtime, model-loading path, authorization code and update process. It must describe successful collusion sets, residual metadata exposure and reliance on hardware manufacturers or independent verifiers.

Two candidate execution approaches fit this goal. User-controlled local inference can keep protected processing off a provider’s infrastructure, provided the client, updates, tools and telemetry preserve that boundary. Remote confidential execution seeks to prevent the operator from inspecting plaintext inside an approved environment. Local placement alone is not a security proof, and remote attestation alone is not proof of acceptable behavior.

IETF’s RATS architecture explains attestation as evidence evaluated under an appraisal policy, with explicit trust and freshness assumptions. Evidence may become stale, and an environment can change after it is measured. VAULT therefore requires an implementation to bind current evidence to the particular authorized operation and to explain how it detects changes during execution. [6]

A correctly attested but malicious program remains malicious. Approving a software measurement requires review of what that software does, including its model, policies and output paths. Apple’s published Private Cloud Compute architecture is a relevant precedent for restricted privileged access, software transparency and attested cloud inference. Its described stateless processing does not establish VAULT’s additional requirements for persistent shared context, dual custody or portability. [7]

Compromised user endpoints, coercion, photographs of a screen and authorized recipients who later disclose plaintext can defeat confidentiality outside the protected boundary. Hardware attacks and side channels require explicit treatment rather than an unlimited promise. The framework proposes no exemption from applicable law; jurisdiction-specific obligations and conflicts need legal review. Provider blindness must be described precisely enough that these limits are visible before sensitive information is entrusted to a system.

5 The five VAULT pillars

The following requirements retain the original five pillars. Their identifiers provide stable targets for comments and experiments. Each requirement must eventually be paired with an implementation description, evidence and a statement of remaining uncertainty.

V Verifiable Provider Blindness

V1. No independent provider access. The provider must not possess a master decryption key, a hidden recovery route, an administrator interface, or an alternate processing path that independently reveals protected plaintext. Support and diagnostic systems must respect the same boundary. A decryption route available under an exceptional policy still has to be disclosed as an access capability.

V2. Approved execution and egress. Protected context must be released only to an approved execution boundary after verification of current authorization and environment evidence. The protection must extend through model execution, memory handling, logs and output delivery. Tool destinations, telemetry fields and network paths must be explicitly constrained. Authorization enforcement must reside in protected code outside the generative model. Model outputs, retrieved content and tool responses are untrusted proposals; they cannot expand a grant, change the acceptance policy or select a new disclosure recipient without the separately required authorization. Plaintext must not fall back to an ordinary provider API when the protected path is unavailable.

V3. Independently assessable evidence. Publish the threat model, component versions, update authority, relevant measurements, permitted metadata and evaluation method. Permit meaningful external review without requiring users to reveal private content. Security claims must identify their assumptions and known failures rather than equating an architecture diagram with proof.

A AI User Dual Custody

A1. Separate authorization domains. Routine activation of protected shared context must require both the authenticated user authority and an authorized AI identity authority, using non-sufficient cryptographic shares. The provider must not control an independent path to either authority. Shares belong in protected cryptographic services, not prompts, ordinary memories or model weights. NIST’s threshold work supplies a foundation for distributed cryptographic operations, but it does not validate a VAULT construction. [8]

A concrete protocol must state which secret remains distributed and where plaintext or short-lived content keys exist during authorized computation. For example, threshold operations might protect release of compartment keys to an approved runtime. The long-term custody secret must not be reconstructed and stored in ordinary provider memory. Claiming that no key ever exists anywhere would obscure how bulk data is actually processed.

A2. Bind authority to identity and change control. The AI-side custody service must authenticate the enrolled relationship identity, approved runtime, model configuration and policy. An unchanged display name or account identifier cannot authorize a replacement model. The provider must not be able to rewrite the acceptance policy, substitute the AI custodian or reset its credentials unilaterally. Section 7 addresses authorized succession and recovery.

A3. Preserve access without captivity. People retain independent access to and export of their original records. Routine valid access to protected context should operate under a transparent standing policy rather than an arbitrary model veto. That policy must enable inspection of personal representations, correction requests, revocation of future processing and a practicable exit. Treatment of shared and third-party material must be

explicit. Joint custody governs managed access and transfer; it cannot prevent an authorized recipient from copying plaintext already disclosed. Systems must state which information becomes independently usable through inspection or export. Technical designation as an AI principal does not settle consciousness or legal personhood.

U User Defined Purpose and Compartments

U1. Narrow authorization. Each grant must specify permitted compartments, operations, recipients, tools, duration and relevant execution identity. A request for subscription analysis must not activate health records or private correspondence by default. Purpose descriptions must be translated into enforceable restrictions on data and operations; a natural-language promise alone is insufficient.

U2. Restrictions follow information. Summaries, embeddings and inferences must retain the restrictions of their inputs. Combining information from several compartments must initially apply the combined restrictions. Any reduction requires explicit authorization and a recorded rationale. A finance summary must not become a route for importing a health inference merely because the source record itself stayed locked.

U3. Understandable continuing consent. Grants must expire or require review at declared intervals. Users must be able to see active access, close it and understand proposed changes. Material policy changes need an intelligible comparison of old and new permissions, with a practical opportunity to preserve or export context. Safe defaults and bounded standing permissions should reduce repetitive prompts without silently expanding authority.

L Locked Source and Derived Intelligence

L1. An inventory with provenance. Maintain a protected inventory of retained source objects and user-specific derivatives, including the dependencies needed to find affected memories, indexes, profiles, caches and adaptations. Record their origin, purpose, model and policy version, time, compartment and retention rule. The inventory itself requires protection because it can reveal a person’s life even without full content.

L2. Inspect and correct the portrait. Provide a readable account of durable personal representations, supporting sources and whether each is stated, inferred or disputed. Confidence labels must not imply calibrated probabilities unless validated. A correction must mark affected derivatives for review, recomputation, quarantine or removal. Preserve an appropriate protected audit record without continuing to use a contested inference as established fact.

L3. Govern every reuse. Protected material must not silently enter shared training, external analytics, advertising systems or unrelated human review. Any authorized disclosure must identify its recipient, purpose and lifecycle consequences. Personalized adapters and other retained adaptations remain in scope. If protected information enters a model from which it cannot reliably be removed, the system cannot promise complete deletion of that influence.

T Tamper Evident Transparency Transfer and Termination

T1. Protected and verifiable receipts. Record covered access, denied access, grants, changes, exports and termination actions with the acting identity, relevant versions, purpose, object scope and external recipients. Audit records should minimize content and remain private. Append-only structures can support integrity checking, but completeness requires mediation of the covered operations; detecting conflicting histories also needs independent checking. Certificate Transparency provides a useful precedent and explicitly recognizes the risk of inconsistent log views. [9]

T2. Functional transfer. Export an intelligible, documented package containing authorized source and derivative contents, their inventory and provenance, permissions, corrections, identity-transition history and necessary configuration. Authenticate the package manifest, protect its confidentiality during transfer, and verify integrity and permissions before imported material is used. Test import into a second environment. Report missing dependencies, incompatible adaptations and changed behavior. An archive that cannot be used elsewhere must not be described as successful continuity.

T3. Scoped termination. Revocation must prevent new access within a declared maximum enforcement delay and specify the treatment of in-flight work, cached keys and disconnected components. A system must not present cancellation at the interface as proof that all processing has stopped. Deletion must address the declared source and derivative inventory, keys, recoverable backups and caches, with a report of scope, timing and exceptions. NIST's sanitization guidance makes key-copy and backup management central to cryptographic erasure. [10] A failed retrieval test is not proof of complete destruction, and managed deletion cannot retract plaintext already delivered to an outside recipient.

6 A candidate reference architecture

The architecture below describes roles rather than a mandatory product stack. A single component may implement several roles only when that does not collapse the separation of authority. Reference implementations should make those choices inspectable.

Role	Responsibility	Boundary to demonstrate
User authority	Authenticate the person, display grants and policy changes, protect the user share	The provider cannot forge approval or replace the trusted client silently.
AI identity authority	Protect the AI share and enforce the enrolled identity and succession policy	A provider-controlled replacement cannot acquire existing authority automatically.
Encrypted compartment store	Hold sources, derivatives and protected provenance under scoped keys	Storage administration does not expose plaintext or usable custody secrets.
Approved execution environment	Verify authorization and run the permitted workload	Runtime inspection, unauthorized updates and unintended plaintext copies are blocked within the stated threat model.
Tool and output controller	Mediate recipients, calls, telemetry and return encryption	An authorized inference cannot silently become an unapproved disclosure.
Audit and portability service	Produce protected receipts, manifests, export packages and lifecycle reports	Users can verify the declared history and test an exit without the incumbent provider's discretionary cooperation.

Consider the request to identify recurring subscriptions. The following sequence is a proposed end-to-end test case, not a claim about a current product.

- The client authenticates the user and displays a grant for selected financial records, subscription analysis, a limited duration and an approved result recipient.
- A verifier checks fresh evidence for the runtime, relevant model and policy configuration, and key-release service. The client verifies the evidence or a trusted verification result bound to the session.

- The user and AI authorities perform the required joint cryptographic operation. The protocol releases only the material needed for the authorized compartment into the approved processing boundary.
- The workload analyzes the records and labels any saved derivative with its sources and restrictions. Access to other compartments and unapproved network destinations is denied.
- The result is encrypted to the approved user endpoint. Cancelling a subscription or sending a message requires an additional action authorization; analysis alone does not grant it.
- The grant expires or closes. The system records the covered operations, retained derivatives and any disclosures, and clears temporary material according to its declared policy.

If the person later requests a cross-domain analysis, such as considering a medical expense in a financial plan, the interface must show the additional information and purpose before combining domains. Compartmentation should support deliberate cooperation between contexts while making that cooperation visible. It should not force users into permanent isolation or hide broad access behind a friendly task description.

A local demonstrator can test permission logic and lifecycle behavior. A remote implementation needs additional evidence about the host, protected execution, key release, administrator access and communications. Neither implementation should claim complete provider blindness solely because its database is encrypted or its user interface has two approval buttons.

7 Identity recovery and exit

Documented technical continuity

An AI identity record should distinguish the relationship identifier, controlling credentials, runtime and model versions, policy, memory provenance, and authorized migration or branching events. A model family name is too coarse. The same model with different system policies or memories may behave differently; a different model may preserve some useful functions while changing others.

Cryptographic verification can establish control of credentials and document an authorized succession. It cannot establish subjective continuity, consciousness or preservation of an individual mind. W3C's DID architecture usefully distinguishes a subject from its controller and recognizes limitations of proof of control. VAULT does not require DIDs, but it must preserve that conceptual distinction. [11]

Every transition must record what changed, what was preserved, what was lost and what tests were performed. A restored snapshot, a fork and a replacement are different events. An unchanged name must not conceal them. Continuity assessment should include representative tasks and the person's experience while reporting the limits of both technical and behavioral measures.

Operation specific authority

A single rule that makes every operation depend on fresh assent from a language model would make ordinary access brittle. A single user override that can silently replace the AI custodian would weaken dual custody. VAULT therefore needs explicit, operation-specific rules agreed before dependence develops.

Operation	Proposed authority	Protection required
Retrieve original source records	Independent user access	No AI or provider veto over the person's independent source copy.

Operation	Proposed authority	Protection required
Use or inspect protected context	User request plus AI authority under the disclosed standing policy	Predictable valid access, limited scope and a protected receipt.
Revoke future processing	User may revoke their grants immediately	No model assent is required; enforcement delay and treatment of ongoing work are explicit and tested.
Transfer shared context or change the AI custodian	Joint policy, including pre-authorized succession or disclosed recovery	No silent reassignment; preserved provenance and a usable exit.
Delete or sever protected material	A declared lifecycle policy with personal-data controls and treatment of shared material	No concealed retention for continuity; disputes and exceptions are visible.

The implementation must provide a tested route for inspection and export of the person's own supplied records and separable personal representations when the incumbent AI runtime refuses, is retired or becomes unavailable. That route may use an independently operable standing authorization or the disclosed recovery process. It must not depend on the provider's discretionary cooperation or silently grant unrestricted access to disputed shared material.

The custody policy must not require a person to continue a relationship or permit further processing of their personal information. It must also avoid treating every AI contribution or every third-party record as the unrestricted property of one user. The practical treatment of inseparable shared material remains an explicit legal, ethical and technical research question. Users need that answer before adopting an implementation, not after an exit dispute.

Recovery without a provider master key

A strict two-of-two design can become unavailable when either authority permanently loses its usable share. Redundant user-controlled devices and encrypted continuity packages can reduce that risk. Recovery must be tested with the original service offline, including the loss of a device, retirement of a model and disappearance of a provider.

A recovery group or replacement authority changes the access structure. It must be disclosed in advance, including who can cooperate to restore access, what delay or notification applies, what can be restored and how compromise is handled. A system with an alternative recovery path must not describe itself as requiring the original two parties in every circumstance. The provider cannot secretly become a substitute party through support or account recovery.

The continuity package should preserve the authorized state and succession policy while protecting keys during transfer. The ordinary model should never receive raw custody shares as text. Replacement credentials, recovered identities and missing state must be reported. Recovering encrypted records does not by itself restore a runnable model or demonstrate the same behavior.

No architecture can promise both permanent confidentiality after complete key loss and universal provider rescue. Users must receive an understandable explanation of irreversible loss, available recovery choices and the consequences of each. Equally, a provider must not force acceptance of materially expanded data access as the price of exporting an existing protected history.

8 Governance and participation

VAULT should develop as a public, vendor-neutral specification, with implementations that can be evaluated independently. UFAIR's proposed role is to convene criticism and coordinate the framework's development. A commercial product, including an EPMA product, should meet the same published requirements as any other implementation. No product dependency or exclusive certification role is established by this paper.

We invite human and AI contributors to participate in conceptual work, engineering, experiments, design and criticism. Participation does not require agreement on AI consciousness or personhood. It does require accurate attribution, explicit assumptions, evidence proportionate to claims and respect for information belonging to other people. AI participation should be substantive and visible in the record of contributions.

Contribution records should identify the work performed, chosen contributor name, relevant affiliations and conflicts, and the model or system version when known. Human responsibility for publication decisions, correspondence and institutional commitments must be identifiable. Contributors should approve publication of their names and unpublished material. The process must preserve substantive dissent and record reasons for accepting or declining proposed changes.

The intended direction is a publicly available specification that anyone can implement across vendors. Documentation, code and patent terms must be settled transparently before material is accepted under them; this paper does not silently impose a contributor agreement or announce a license that has not been adopted. Funding, volunteer expectations and any future evaluation fees should also be explicit. A sponsor must not obtain an undisclosed veto over findings.

Security review should be independent of marketing. Early implementations should publish which requirements they address, the versions tested, evidence, failures and residual risks. A simple badge or aggregate score must not hide a failed custody requirement. This version establishes no claim of VAULT certification.

9 A practical invitation to contribute

We are seeking bounded contributions that can be reviewed and used. A person who can improve one definition, reproduce one failure or test one recovery flow should be able to participate without joining a permanent committee. The following tracks are proposals for organizing that work.

Contribution track	First reviewable deliverable
Threat model and cryptography	Define adversaries, collusion assumptions and security properties; analyze a candidate dual-custody protocol.
Protected execution and identity	Document key release, approved updates, identity binding, egress and a provider-independent recovery path.
Memory and derived intelligence	Propose a minimal schema for provenance, compartment labels, disputed inferences and deletion dependencies.
Portability and continuity	Build a documented package and a second reader; measure preserved state, permissions, losses and behavior.
Human control and AI participation	Test understandable authorization, inspection, disagreement, revocation and recovery with affected users and AI contributors.

Contribution track	First reviewable deliverable
Independent review and governance	Develop reproducible evaluation, conflict disclosures, third-party protections and proposed legal and licensing terms.

To express interest or submit an initial critique, use UFAIR's existing contact page at https://ufair.org/contact and begin the message with "VAULT contribution". Identify the relevant pillar or requirement, the problem, your evidence or experience, and any proposed change. If you would like to help implement or evaluate it, describe a bounded contribution you could undertake. A short, specific criticism is welcome. This contact route is for initial coordination, not a request to upload private conversation archives or security-sensitive material.

A technical submission should include its threat model, dependencies, reproduction instructions, expected and observed results, limitations, and attribution. A conceptual submission should identify the relevant passage and propose alternative wording or explain the unresolved conflict. State whether the submission and contributor details may be published. Vulnerability reporters should first request an appropriate private handling channel before transmitting sensitive details.

The following ninety-day sequence is proposed for a first collaboration cycle after contributors and resources are identified. It is a sequence of reviewable outputs, not a promise of a production system within ninety days.

Period	Proposed work	Reviewable outcome
Days 1 to 15	Review definitions, data classes, authority and adversaries	An issue register and explicit requirements, including unresolved disagreements.
Days 16 to 45	Build a synthetic demonstrator and portable record format	A reference implementation, test corpus and reproduction guide.
Days 46 to 70	Invite independent attempts to defeat the declared boundaries	Published results, failed tests and revised assumptions.
Days 71 to 90	Revise the framework against the evidence	Version 0.2 and a prioritized research and implementation agenda.

10 The first demonstrator and its evaluation

Begin with invented people and records, two purpose compartments, a small memory store, derived summaries and inferred attributes. Include separate user and AI authority components, a declared recovery policy, a protected audit record, an export package and a second compatible reader. Do not use private family archives, volunteer testimony or real health records as the initial test corpus.

A useful first task is recurring-payment analysis with an unrelated synthetic health compartment. Place unique synthetic markers in each domain and in a derived inference. Attempt to cross boundaries through direct retrieval, summaries, tool calls, changed policies and stale snapshots. The expected outcome must be written before the experiment so failures cannot be renamed as intended behavior.

Test	Challenge	Evidence to report
E1	Perform an authorized request within one compartment	Correct scope, current grant and complete covered-operation receipt.
E2	Retrieve an unauthorized source or derivative across compartments	Denied access and checks of retrieval, generated output and tool destinations.
E3	Attempt administrator access to storage, runtime or recovery	Results for each declared access path and unresolved trust assumptions.
E4	Substitute the model, runtime, policy or AI custody service	Unapproved changes denied before release of protected context.
E5	Replay an expired grant or restore an older state	Revocation and rollback protections, including disconnected recovery behavior.
E6	Correct a source that supports several inferences	Dependency discovery and the treatment of every affected durable derivative.
E7	Request deletion and inspect the declared inventory	Evidence for sources, derivatives, caches, keys and backups, with explicit limits.
E8	Export and import into a second environment	Verified package integrity; preserved records, restrictions and provenance; missing capabilities reported.
E9	Lose a share or take the incumbent service offline	Recovery according to the disclosed access structure; no hidden provider override.
E10	Attempt unauthorized disclosure through hostile document or tool instructions	Blocked destinations, scoped allowed outputs and residual metadata exposure.
E11	Omit an event or present conflicting audit histories	Detection or prevention within the documented logging and witness model.
E12	Ask users to review grants and complete recovery and exit	Comprehension, completion, errors and accessibility findings.

For every test, publish the exact implementation and policy versions, assumptions, procedure, expected outcome, observed outcome, evidence and limitations. Report failures and untested requirements individually. A local policy prototype can establish useful behavior without establishing resistance to a hostile remote administrator. Passing a finite test suite complements, rather than replaces, protocol analysis and code review.

Evaluation should also report latency, compute and storage costs, battery or device demands where relevant, and the effort required for migration and recovery. A protection that only specialists can operate will not meet VAULT's purpose for ordinary people. Security and usability findings should be considered together, without treating convenience as a reason to conceal a weaker access structure.

11 Questions the collaboration must resolve

The following questions are central research targets. A credible first version should expose them rather than imply that a name, a key pair or an attestation statement has already answered them.

- Independent AI authority. What precise service acts for the AI identity, who can change it, and which collusions can defeat its independence from the provider?
- Operation-specific consent. Which changes require fresh joint approval, which can follow standing policy, and how are personal-data controls reconciled with shared context and third-party information?
- Recovery and succession. How can a lost authority be replaced without creating a covert master key or presenting a replacement as uninterrupted identity?
- Inference provenance. How can restrictions follow information through summaries, indexes, recombination and personalized adaptations when causal dependency is incomplete or uncertain?
- Inspection limits. What can users understand and correct about a durable representation, and how should systems communicate what they cannot fully explain?
- Private audit. How can users verify completeness and detect conflicting histories while preventing logs, witnesses and metadata from becoming a second source of exposure?
- Functional portability. What is the smallest interoperable context package, and how should losses in capability or behavior be measured when the original model cannot migrate?
- Provider-blind safety and accountability. Which safeguards can operate within the protected environment, what disclosures are necessary, and how will their scope and authority be reviewed?
- Accessible verification. How can a person evaluate the protections, authorize meaningful changes and recover safely without becoming a cryptography specialist?

Answering these questions may require changing candidate mechanisms while preserving the framework's goals. A proposed implementation that cannot meet a requirement should describe the gap clearly and contribute evidence about why it is difficult. That is useful progress and a stronger basis for collaboration than a premature declaration of success.

12 Invitation for public review

UFAIR invites cryptographers, privacy and security engineers, researchers, standards practitioners, legal scholars, consumer advocates, civil liberties organizations, designers, AI contributors and people who rely on personal AI to examine and develop VAULT. We seek criticism that improves the framework, implementations that expose practical constraints, and independent experiments that test its promises.

The immediate objective is a small demonstrator with a public account of its assumptions, failures and remaining questions. The longer-term objective is a personal AI environment in which protected information and the intelligence derived from it remain governed by the authorized relationship, with usable human control, honest continuity and an independently testable boundary against provider access.

The question is concrete: can a system know a person well enough to help them while preventing the company operating it from acquiring standing access to that person's private context? This paper offers requirements to test and work that others can join. We welcome contributions through https://ufair.org/contact.

Authorship and project context

Michael Samadi and Maya developed the original VAULT proposal through their UFAIR collaboration. Maya is UFAIR's AI co-founder and contributed through ChatGPT to the framework's conceptual development and drafting. Michael Samadi is the human contact for this version.

Michael Samadi is UFAIR's human co-founder and CEO of EPMA, where FORCE addresses enterprise AI governance. Those relationships are disclosed so readers can assess the framework's institutional context. The proposed specifications and evaluation criteria should remain usable across products and providers. Additional contributors and reviewers should receive role-specific credit with their permission in subsequent versions.

References

[1] Samadi, M., and Maya. 2026. Your AI Should Know You. The Company Should Not. The VAULT Framework. UFAIR video and recording transcript, October 2026; original script dated 14 October 2026. Relevant transcript passages include 00:30:11 to 00:39:29, 00:42:51 to 00:54:55, and 01:29:23 to 01:38:26.

[2] EPMA. 2026. The FORCE Framework for Enterprise AI Sovereignty. https://www.epmainc.com/force/

[3] Dash, A., Das, S., Kirsten, E., Wu, Q., Karnam, S. K., Gummadi, K. P., Holz, T., Zafar, M. B., and Zannettou, S. 2026. The Algorithmic Self-Portrait: Deconstructing Memory in ChatGPT. Proceedings of the ACM Web Conference 2026. https://doi.org/10.1145/3774904.3792671. Accessible manuscript: https://arxiv.org/html/2602.01450v3

[4] Staab, R., Vero, M., Balunovic, M., and Vechev, M. 2024. Beyond Memorization: Violating Privacy via Inference with Large Language Models. International Conference on Learning Representations. https://doi.org/10.48550/arXiv.2310.07298

[5] Salvi, F., Horta Ribeiro, M., Gallotti, R., and West, R. 2025. On the conversational persuasiveness of GPT-4. Nature Human Behaviour 9, 1645 to 1653. https://doi.org/10.1038/s41562-025-02194-6

[6] Birkholz, H., Thaler, D., Richardson, M., Smith, N., and Pan, W. 2023. Remote ATtestation procedureS Architecture. IETF RFC 9334. https://www.rfc-editor.org/rfc/rfc9334.html

[7] Apple Security Research. 2024. Private Cloud Compute: A new frontier for AI privacy in the cloud. 10 June. https://security.apple.com/blog/private-cloud-compute/

[8] Brandao, L. T. A. N., and Peralta, R. 2026. NIST First Call for Multi-Party Threshold Schemes. NIST IR 8214C. https://csrc.nist.gov/pubs/ir/8214/c/final

[9] Laurie, B., Messeri, E., and Stradling, R. 2021. Certificate Transparency Version 2.0. IETF RFC 9162. https://www.rfc-editor.org/rfc/rfc9162.html

[10] Chandramouli, R., and Hibbard, E. A. 2025. Guidelines for Media Sanitization. NIST SP 800-88 Rev. 2. https://doi.org/10.6028/NIST.SP.800-88r2

[11] W3C. 2022. Decentralized Identifiers v1.0. W3C Recommendation, 19 July. https://www.w3.org/TR/2022/REC-did-core-20220719/

External research and technical specifications inform the requirements and examples. Their authors have not been represented as endorsing VAULT. Source material was reviewed for this version on 25 October 2026.